
**CONCEPTO
ARQUITECTURA EMPRESARIAL
IFRAME VISUALIZACIÓN DE DATOS SENSIBLES
(PAN/CVV2)
CREDIBANCO**

VERSIÓN 1.0

HISTORIA DE REVISIONES

Fecha	Versión	Descripción	Autor
30/04/2026	1.0	Versión Inicial	Javier Ricardo Agudelo

TABLA DE CONTENIDO

- GUÍA DE USO.....4
- NECESIDAD.....5
- PREMISAS DEL CONCEPTO7
- LINEAMIENTOS9
- RESTRICCIONES.....12
- ARQUITECTURA PROPUESTA15
 - Diagrama de Arquitectura.....15
 - Descripción de componentes17
 - Descripción del proceso.....19
 - Aplicaciones y/o soluciones afectadas25
- ANEXOS.....26

GUÍA DE USO

El presente documento detalla el concepto del equipo de arquitectura empresarial generado para la necesidad expuesta por el negocio. Se identifica la necesidad, premisas, lineamientos, restricciones y se detalla la arquitectura propuesta.

A su vez, contiene el detalle de los elementos evaluados y el análisis a alto nivel de los posibles componentes involucrados dentro de Credibanco.

Cómo diligenciar este documento:

- No se deben eliminar las anotaciones al inicio de cada sección con información de lo que debe contener cada punto. Estas notas sirven para ayudar a determinar la información a rellenar y para ayudar a las personas que revisan el documento a saber que debe estar cumplimentado en cada apartado.
- No se deben eliminar puntos del índice o capítulos del documento. Si algún punto no aplica se pondrá el comentario "NO APLICA".
- No olvide actualizar la fecha y la versión del documento en el encabezado, y el nombre del archivo en el pie de página.
- Tenga la precaución de revisar todos los encabezados y pies de página del documento para confirmar que la información que figura en los mismos está correctamente actualizada, ya que hay encabezados y pies de página para diferentes secciones del documento, y para páginas pares e impares.

NECESIDAD

El presente concepto se enfoca en definir la arquitectura propuesta para la visualización segura de datos sensibles de tarjetas prepago, específicamente el PAN completo, fecha de vencimiento y CVV2, desde el Portal Tarjetahabiente.

La necesidad surge porque el tarjetahabiente requiere consultar los datos completos de su tarjeta prepago para realizar operaciones no presenciales, validar la información de su tarjeta o utilizarla en comercios digitales. Sin embargo, esta funcionalidad debe implementarse bajo un modelo que reduzca al máximo la exposición de datos sensibles y evite que el portal de la entidad emisora procese, transmita, almacene o renderice directamente información de tarjeta.

Para atender esta necesidad, se propone que la visualización de los datos sensibles se realice exclusivamente mediante un iframe seguro, alojado en un dominio controlado por Credibanco, por ejemplo `secure-data.credibanco.com`, separado del dominio del Portal Tarjetahabiente de la entidad, por ejemplo `portal.entidad.com`.

Bajo este modelo, el Portal Tarjetahabiente actúa únicamente como canal autenticado de acceso del usuario, pero no recibe ni manipula datos sensibles de tarjeta. La responsabilidad de solicitar, procesar y renderizar PAN/CVV2 recae sobre componentes controlados por Credibanco y considerados dentro del alcance CDE, tales como el iframe seguro, el Backend Card Data API y los componentes criptográficos asociados, como HSM o Vault.

La necesidad principal es habilitar una experiencia segura para el tarjetahabiente, permitiéndole visualizar los datos de su tarjeta cuando sea requerido, sin comprometer el cumplimiento de los lineamientos de seguridad y PCI DSS aplicables.

Las necesidades identificadas son las siguientes:

- Permitir que el tarjetahabiente consulte los datos completos de su tarjeta prepago desde el Portal Tarjetahabiente.
- Evitar que el Portal Tarjetahabiente de la entidad emisora procese, transmita, almacene o renderice PAN completo y CVV2.
- Centralizar la visualización de datos sensibles en un iframe seguro alojado en un dominio controlado por Credibanco.
- Mantener una separación técnica entre el portal de la entidad y los componentes que hacen parte del entorno CDE.
- Validar que el usuario cuente con sesión autenticada y MFA vigente antes de visualizar datos sensibles.
- Garantizar que la comunicación entre el portal y el iframe no incluya datos sensibles, sino únicamente identificadores opacos y referencias controladas.
- Utilizar un viewToken de un solo uso y corta duración para autorizar cada visualización.
- Obtener el PAN desde componentes seguros de custodia y descifrado, como HSM o Vault.
- Adoptar CVV2 dinámico generado por Pomelo como opción preferente, evitando almacenar CVV2 estático en los sistemas de Credibanco.
- Renderizar el PAN enmascarado por defecto y permitir la visualización completa únicamente mediante acción explícita del tarjetahabiente.
- Limitar el tiempo de exposición de los datos sensibles mediante auto-ocultamiento después de un periodo definido.
- Evitar almacenamiento de PAN/CVV2 en caché, cookies, localStorage, sessionStorage o logs.
- Registrar auditoría de cada evento de visualización sin incluir PAN, CVV2 ni datos sensibles en los registros.
- Documentar claramente los controles reales de seguridad y diferenciarlos de los controles de reducción de exposición.
- Validar formalmente con Seguridad de la Información y el asesor/auditor PCI el alcance CDE propuesto y la compatibilidad del diseño con la próxima auditoría PCI.

En consecuencia, este concepto busca establecer una arquitectura que permita cumplir la necesidad funcional de visualización de datos de tarjeta, manteniendo una postura

conservadora de seguridad, minimizando la exposición de información sensible y delimitando claramente las responsabilidades entre el Portal Tarjetahabiente, el iframe seguro, el Backend Card Data API, el HSM/Vault y Pomelo.

PREMISAS DEL CONCEPTO

Esta sección presenta las premisas que rigen la arquitectura propuesta para la visualización segura de datos sensibles de tarjetas prepago mediante iframe seguro.

- El tarjetahabiente ya se encuentra autenticado en el Portal Tarjetahabiente antes de solicitar la visualización de los datos de su tarjeta.
- El Portal Tarjetahabiente opera en un dominio diferente al dominio donde se aloja el iframe seguro.
- El Portal Tarjetahabiente no deberá procesar, transmitir, almacenar ni renderizar directamente datos sensibles de tarjeta como PAN completo o CVV2.
- El Portal Tarjetahabiente se limitará a cargar el iframe seguro y a enviar referencias no sensibles mediante postMessage.
- La comunicación entre el Portal Tarjetahabiente y el iframe no deberá incluir PAN, CVV2, fecha de vencimiento completa ni ningún otro dato sensible de tarjeta.
- El iframe seguro estará alojado en un dominio controlado por Credibanco, por ejemplo secure-data.credibanco.com.
- El iframe seguro será el único componente frontend autorizado para renderizar los datos sensibles de la tarjeta.
- El iframe seguro, el Backend Card Data API, el HSM/Vault y los canales asociados al procesamiento de PAN/CVV2 se consideran componentes dentro del alcance CDE propuesto.
- El Portal Tarjetahabiente se propone fuera del alcance CDE, dado que no procesa, transmite, almacena ni renderiza PAN/CVV2; esta clasificación queda sujeta a validación formal por Seguridad de la Información y el asesor/auditor PCI.
- El navegador y dispositivo del tarjetahabiente son entornos no controlados por Credibanco, por lo que se consideran puntos de visualización temporal con riesgos residuales documentados.
- Cada visualización de datos sensibles deberá estar precedida por una validación de sesión activa y MFA vigente.
- El MFA deberá operar como un control de autenticación reforzada antes de permitir la exposición temporal de PAN/CVV2.
- El iframe solicitará los datos sensibles directamente al Backend Card Data API, no al Portal Tarjetahabiente.
- El Backend Card Data API será responsable de validar sesión, MFA, titularidad de la tarjeta, autorización, vigencia del viewToken y límites de uso antes de entregar datos sensibles al iframe.
- El viewToken será de un solo uso, tendrá un TTL máximo de 30 segundos y estará ligado al usuario, tarjeta, sesión, operación y estado de MFA.
- El cardId o identificador enviado al iframe deberá ser un identificador opaco, no derivado del PAN, no enumerable y no reversible.
- El backend no deberá confiar únicamente en el cardId; siempre deberá validar titularidad, sesión, MFA, autorización y viewToken.
- El PAN completo se obtendrá desde componentes seguros de custodia y descifrado, como HSM o Vault, dentro del perímetro CDE definido.
- El PAN deberá permanecer cifrado en almacenamiento y solo podrá ser descifrado en el proceso estrictamente necesario para su visualización autorizada.
- El CVV2 estático no será almacenado en sistemas de Credibanco.
- La opción preferente para CVV2 será el uso de CVV2 dinámico generado por Pomelo, consultado en tiempo real y con TTL limitado.
- En caso de indisponibilidad de Pomelo para generar CVV2 dinámico, el sistema no deberá recurrir a CVV2 estático almacenado ni a mecanismos de contingencia que impliquen persistencia local del CVV2.
- La respuesta del Backend Card Data API hacia el iframe deberá viajar cifrada mediante TLS 1.3 y con headers que impidan almacenamiento en caché.

- El iframe renderizará el PAN enmascarado por defecto, mostrando inicialmente solo los últimos cuatro dígitos.
- La visualización del PAN completo y CVV2 requerirá una acción explícita del tarjetahabiente.
- Los datos sensibles revelados deberán auto-ocultarse después de 30 segundos.
- Después del tiempo de visualización, el iframe deberá eliminar los datos sensibles del DOM y limpiar las referencias en memoria del componente frontend.
- El iframe no deberá almacenar PAN ni CVV2 en localStorage, sessionStorage, cookies, caché del navegador ni mecanismos equivalentes.
- Las protecciones anti-copia, como user-select: none y bloqueo de eventos copy, cut, paste o contextmenu, se consideran controles de reducción de exposición, no controles absolutos de seguridad.
- El diseño reconoce como riesgos residuales las capturas de pantalla, fotografías externas del monitor, malware en el endpoint del usuario e inspección mediante herramientas avanzadas del navegador.
- La mitigación principal frente a la exposición en pantalla será la combinación de MFA, viewToken de un solo uso, tiempo limitado de visualización, auto-ocultamiento y auditoría.
- Todos los eventos de visualización deberán registrarse en auditoría sin incluir PAN, CVV2 ni payloads sensibles.
- La auditoría deberá incluir, como mínimo, identificador interno de tarjeta, usuario, timestamp, IP, user-agent, resultado de la operación y correlationId.
- El diseño deberá ser revisado por Seguridad de la Información para validar los controles propuestos, los riesgos residuales y el alcance CDE.
- El diseño deberá ser validado frente a PCI DSS v4.0.1 y frente a los criterios definidos por el asesor o auditor PCI correspondiente.

LINEAMIENTOS

Esta sección presenta los lineamientos que rigen la arquitectura propuesta para la visualización segura de datos sensibles de tarjetas prepago mediante iframe seguro.

- La solución deberá aplicar el principio de mínima exposición de datos sensibles, limitando el acceso, procesamiento y visualización de PAN/CVV2 únicamente a los componentes estrictamente necesarios.
- El Portal Tarjetahabiente no deberá procesar, transmitir, almacenar, renderizar ni registrar PAN completo, CVV2 o datos sensibles equivalentes.
- El Portal Tarjetahabiente únicamente deberá cargar el iframe seguro y enviar referencias no sensibles mediante postMessage.
- Toda comunicación entre el Portal Tarjetahabiente y el iframe deberá realizarse sin incluir PAN, CVV2, fecha de vencimiento completa, datos de autenticación sensibles o información que permita reconstruir datos de tarjeta.
- El iframe seguro deberá estar alojado en un dominio controlado por Credibanco, separado del dominio del Portal Tarjetahabiente.
- El iframe deberá ser el único componente frontend autorizado para renderizar PAN completo, fecha de vencimiento y CVV2.
- El iframe deberá validar de forma estricta el origen de cada mensaje recibido mediante postMessage, incluyendo como mínimo event.origin, event.source, estructura del mensaje y acción solicitada.
- El iframe solo deberá aceptar mensajes provenientes de dominios previamente autorizados y registrados en una lista blanca.
- El cardId utilizado para referenciar la tarjeta deberá ser un identificador opaco, no derivado del PAN, no reversible, no enumerable y no reutilizable fuera del contexto autorizado.
- El backend no deberá confiar únicamente en el cardId; deberá validar siempre sesión activa, MFA vigente, titularidad de la tarjeta, autorización del usuario, estado de la tarjeta y vigencia del viewToken.
- La visualización de datos sensibles deberá requerir MFA vigente antes de cada evento de consulta o revelación.
- El MFA deberá operar como control de autenticación reforzada o step-up antes de permitir la exposición temporal del PAN completo y CVV2.
- Cada solicitud de visualización deberá estar asociada a un viewToken de un solo uso.
- El viewToken deberá tener un TTL máximo de 30 segundos.
- El viewToken deberá quedar ligado a usuario, sesión, tarjeta, operación, origen autorizado, estado de MFA y correlationId.
- El viewToken deberá invalidarse inmediatamente después de su uso, expiración o intento fallido de validación.
- El Backend Card Data API deberá validar todas las solicitudes antes de entregar datos sensibles al iframe.
- El Backend Card Data API deberá operar dentro del alcance CDE propuesto, dado que procesa, descifra o transmite datos sensibles de tarjeta.
- El PAN deberá permanecer cifrado en almacenamiento y solo podrá ser descifrado de forma controlada dentro del flujo autorizado de visualización.
- El descifrado del PAN deberá realizarse mediante componentes seguros de custodia criptográfica, como HSM o Vault, bajo los controles definidos para el CDE.
- El CVV2 estático no deberá almacenarse en sistemas de Credibanco.
- Ante indisponibilidad de Pomelo, el iframe deberá informar al tarjetahabiente que la visualización de los datos no se encuentra disponible temporalmente.
- La comunicación entre iframe y Backend Card Data API deberá realizarse mediante TLS 1.3.
- La comunicación entre Backend Card Data API y HSM/Vault deberá realizarse mediante canal seguro, preferiblemente mTLS.

- La comunicación entre Backend Card Data API y Pomelo deberá realizarse mediante canal seguro, con mTLS y los controles de autenticación definidos para la integración.
- Las respuestas del Backend Card Data API que contengan datos sensibles deberán incluir headers de no almacenamiento, como Cache-Control: no-store, Pragma: no-cache y X-Content-Type-Options: nosniff.
- El Backend Card Data API no deberá permitir almacenamiento en caché de respuestas que contengan PAN, CVV2 o datos sensibles.
- El iframe no deberá almacenar PAN, CVV2 ni datos sensibles en localStorage, sessionStorage, cookies, IndexedDB, caché del navegador o mecanismos equivalentes.
- El PAN deberá renderizarse enmascarado por defecto, mostrando únicamente los últimos cuatro dígitos.
- La visualización del PAN completo y CVV2 deberá requerir una acción explícita del tarjetahabiente.
- La exposición del PAN completo y CVV2 deberá ser temporal, con auto-ocultamiento máximo a los 30 segundos.
- Al finalizar el tiempo de visualización, el iframe deberá reemplazar los valores sensibles por datos enmascarados.
- Después del auto-ocultamiento, el iframe deberá eliminar los datos sensibles del DOM y limpiar las referencias en memoria del componente frontend.
- El iframe deberá notificar al Portal Tarjetahabiente únicamente el estado de la visualización, sin enviar PAN, CVV2 ni datos sensibles.
- El portal padre no deberá recibir datos sensibles como resultado de la visualización.
- Se deberán aplicar políticas CSP estrictas en el iframe, incluyendo restricción de frame-ancestors a portales autorizados.
- Se deberá restringir script-src a fuentes confiables y, cuando aplique, utilizar SRI para scripts autorizados.
- Se deberá restringir CORS para que el Backend Card Data API acepte solicitudes únicamente desde el dominio autorizado del iframe.
- Se deberán implementar controles de rate limiting por usuario, tarjeta, IP y ventana de tiempo.
- Como lineamiento inicial, se propone un máximo de 3 visualizaciones por tarjeta por hora, sujeto a validación de Seguridad de la Información.
- Se deberán implementar controles de auditoría para cada evento de solicitud, visualización, revelación, expiración, error o rechazo.
- La auditoría deberá registrar como mínimo usuario, identificador interno de tarjeta, timestamp, IP, user-agent, resultado, origen, operación y correlationId.
- Los logs no deberán contener PAN completo, CVV2, payloads sensibles, respuestas completas del backend ni datos equivalentes.
- Se deberán aplicar mecanismos de sanitización y enmascaramiento de logs en todas las capas del flujo.
- Las protecciones anti-copia, como user-select: none, bloqueo de copy, cut, paste y contextmenu, deberán documentarse como controles de reducción de exposición, no como controles absolutos de seguridad.
- El diseño deberá reconocer como riesgos residuales las capturas de pantalla, fotografías externas, malware en el endpoint del usuario y uso avanzado de herramientas del navegador.
- La mitigación principal frente a la exposición en pantalla deberá ser la combinación de MFA, viewToken de un solo uso, tiempo limitado de visualización, auto-ocultamiento, no almacenamiento y auditoría.
- La solución deberá contar con WAF o controles equivalentes para proteger los endpoints públicos o expuestos del iframe y del Backend Card Data API.
- Se deberán realizar pruebas de seguridad sobre CSP, CORS, postMessage, reutilización de viewToken, headers de no caché, sanitización de logs, rate limiting y autorización.
- Se deberá generar evidencia técnica de los controles implementados para soportar la revisión de Seguridad de la Información y la auditoría PCI.

- El alcance CDE propuesto deberá ser validado formalmente por Seguridad de la Información y por el asesor o auditor PCI correspondiente.
- La arquitectura deberá alinearse con PCI DSS v4.0.1 y con los lineamientos internos de Credibanco para manejo de datos sensibles de tarjeta.
- Cualquier cambio futuro sobre el flujo de visualización, manejo de CVV2, almacenamiento de datos sensibles, dominios autorizados, tokens o controles criptográficos deberá pasar por revisión de Arquitectura Empresarial y Seguridad de la Información.

RESTRICCIONES

Esta sección presenta las restricciones que rigen la arquitectura propuesta para la visualización segura de datos sensibles de tarjetas prepago mediante iframe seguro.

- El Portal Tarjetahabiente no deberá procesar, transmitir, almacenar, renderizar ni registrar datos sensibles de tarjeta, tales como PAN completo, CVV2 o payloads equivalentes.
- El Portal Tarjetahabiente solo podrá interactuar con el iframe seguro mediante referencias no sensibles, como identificadores opacos, acciones permitidas y correlationId.
- El Portal Tarjetahabiente no deberá recibir datos sensibles desde el iframe, el Backend Card Data API, el HSM o Pomelo.
- La clasificación del Portal Tarjetahabiente como componente fuera del CDE queda sujeta a validación formal por Seguridad de la Información y por el asesor o auditor PCI.
- El iframe seguro, el Backend Card Data API, el HSM y los canales asociados al procesamiento o visualización de PAN/CVV2 deberán considerarse dentro del alcance CDE propuesto.
- El navegador y el dispositivo del tarjetahabiente no son entornos controlados por Credibanco, por lo que la arquitectura no puede impedir de forma absoluta capturas de pantalla, fotografías externas, malware local o inspección avanzada desde herramientas del navegador.
- Las protecciones anti-copia implementadas en el iframe, como bloqueo de selección, copiar, cortar, pegar o menú contextual, no deberán considerarse controles absolutos de seguridad.
- El diseño solo puede reducir la ventana de exposición de los datos sensibles en pantalla; no puede eliminar completamente el riesgo asociado a la visualización en el endpoint del usuario.
- El flujo depende de que el tarjetahabiente cuente con una sesión autenticada vigente en el Portal Tarjetahabiente.
- El flujo depende de que el mecanismo MFA esté disponible y pueda validar al usuario antes de cada visualización.
- Si el MFA no se encuentra disponible, no se deberá permitir la visualización de PAN completo ni CVV2.
- El flujo depende de que el iframe seguro pueda ser cargado correctamente desde el dominio controlado por Credibanco.
- El iframe solo podrá ser embebido por portales previamente autorizados mediante configuración de frame-ancestors y controles equivalentes.
- El iframe no deberá aceptar mensajes postMessage provenientes de orígenes no autorizados.
- El cardId utilizado para referenciar la tarjeta deberá ser opaco, no derivado del PAN, no reversible y no enumerable.
- El cardId no podrá ser utilizado como único factor de autorización para acceder a datos sensibles.
- El Backend Card Data API siempre deberá validar sesión, MFA, titularidad, autorización, estado de la tarjeta, origen autorizado y vigencia del viewToken.
- El viewToken deberá ser de un solo uso y tendrá una vigencia máxima de 30 segundos.
- Una vez consumido o expirado, el viewToken no podrá reutilizarse.
- El tiempo de visualización de PAN completo y CVV2 estará limitado a un máximo de 30 segundos.
- Al finalizar el tiempo de visualización, los datos deberán ser enmascarados, eliminados del DOM y limpiados de memoria en el componente frontend.
- El PAN deberá permanecer cifrado en almacenamiento y solo podrá ser descifrado durante el flujo autorizado de visualización.

- El descifrado del PAN deberá realizarse mediante el HSM definido para la custodia de datos cifrados.
- El Backend Card Data API no deberá persistir PAN completo ni CVV2 en bases de datos, archivos, logs, cachés o colas.
- Las respuestas que contengan datos sensibles no deberán almacenarse en caché en ninguna capa de la solución.
- El iframe no deberá utilizar localStorage, sessionStorage, cookies, IndexedDB ni caché del navegador para almacenar PAN, CVV2 o datos equivalentes.
- El CVV2 estático no deberá almacenarse en sistemas de Credibanco, incluso si se propone cifrado.
- La solución adoptará como enfoque preferente el CVV2 dinámico generado por Pomelo.
- El flujo de visualización del CVV2 dependerá de la disponibilidad de la API de Pomelo para la generación o entrega del CVV2 dinámico.
- Si Pomelo no se encuentra disponible, el sistema no deberá recurrir a CVV2 estático almacenado ni a mecanismos de contingencia que impliquen almacenamiento local del CVV2.
- Ante indisponibilidad de Pomelo, el iframe deberá informar al tarjetahabiente que la visualización de los datos no se encuentra disponible temporalmente.
- La comunicación entre iframe y Backend Card Data API deberá realizarse exclusivamente mediante TLS 1.3 o el estándar corporativo vigente aprobado por Seguridad de la Información.
- La comunicación entre Backend Card Data API y HSM deberá realizarse mediante canal seguro, preferiblemente mTLS.
- La comunicación entre Backend Card Data API y Pomelo deberá realizarse mediante canal seguro, con mTLS y controles de autenticación definidos para la integración.
- El Backend Card Data API deberá restringir CORS únicamente al dominio autorizado del iframe.
- El Backend Card Data API no deberá aceptar solicitudes directas desde el Portal Tarjetahabiente para obtener PAN completo o CVV2.
- El Portal Tarjetahabiente no deberá invocar directamente servicios de descifrado, HSM o API de datos sensibles.
- El portal padre no deberá tener mecanismos para leer, inspeccionar o manipular el DOM interno del iframe.
- La solución deberá operar con CSP estricta, restringiendo frame-ancestors, script-src y demás directivas aplicables.
- La solución dependerá de una configuración correcta y vigente de CSP, CORS, headers de seguridad y dominios autorizados.
- Cualquier mala configuración de CSP, CORS, postMessage o headers de seguridad podrá afectar el alcance de seguridad del diseño y deberá tratarse como riesgo crítico.
- El rate limiting propuesto, inicialmente de máximo 3 visualizaciones por tarjeta por hora, queda sujeto a validación de Seguridad de la Información.
- La solución deberá bloquear o rechazar solicitudes que excedan los límites definidos por usuario, tarjeta, IP o ventana de tiempo.
- Los logs técnicos y funcionales no deberán incluir PAN completo, CVV2, payloads sensibles, respuestas completas del backend ni datos equivalentes.
- La auditoría deberá registrar eventos de visualización sin almacenar datos sensibles de tarjeta.
- La solución deberá garantizar trazabilidad suficiente para revisión de Seguridad, monitoreo, investigación de eventos y auditoría PCI.
- El alcance de los requisitos PCI DSS v4.0.1 aplicables deberá ser validado por Seguridad de la Información y por el asesor o auditor PCI.
- La compatibilidad de este flujo con la próxima auditoría PCI no se considera automática; deberá ser confirmada formalmente.

- La arquitectura propuesta no contempla que terceros diferentes a Credibanco tengan acceso directo a los componentes dentro del CDE, salvo integraciones controladas y aprobadas.
- La solución dependerá de la correcta segregación de ambientes, roles, permisos y accesos administrativos sobre el iframe, backend, HSM y componentes de auditoría.
- Los accesos administrativos a componentes dentro del CDE deberán cumplir con mínimo privilegio, segregación de funciones y trazabilidad.
- La solución deberá contar con pruebas de seguridad previas a producción, incluyendo validaciones sobre iframe, postMessage, CORS, CSP, tokens, rate limiting, headers, logging y autorización.
- Cualquier modificación posterior al diseño, como cambio de dominio del iframe, modificación del manejo de CVV2, ajustes de TTL, nuevos portales autorizados o cambios en el modelo, deberá ser revisada por Arquitectura Empresarial y Seguridad de la Información.

ARQUITECTURA PROPUESTA

Esta sección describe la arquitectura propuesta para la visualización segura de datos sensibles de tarjetas prepago, específicamente PAN completo, fecha de vencimiento y CVV2, mediante un iframe seguro alojado en un dominio controlado por Credibanco.

La solución se basa en una separación explícita de responsabilidades entre el Portal Tarjetahabiente, el Iframe Card Data, el Backend Card Data API, el HSM/Vault y la integración con Pomelo para la generación de CVV2 dinámico.

El objetivo arquitectónico es permitir que el tarjetahabiente visualice los datos completos de su tarjeta cuando sea requerido, sin que el Portal Tarjetahabiente de la entidad emisora procese, transmita, almacene o renderice directamente datos sensibles de tarjeta.

Bajo este diseño, el Portal Tarjetahabiente actúa únicamente como canal autenticado de acceso y contenedor del iframe. Los datos sensibles se solicitan, procesan y renderizan exclusivamente dentro de componentes controlados por Credibanco y considerados dentro del alcance CDE propuesto.

Diagrama de Arquitectura

Diagrama 1. Visualización segura de datos sensibles PAN/CVV2 mediante iframe

El diagrama de arquitectura representa el flujo de visualización en seis fases principales:

1. El Portal Tarjetahabiente carga el iframe seguro y envía una referencia opaca de tarjeta mediante postMessage.
2. El iframe solicita los datos sensibles al Backend Card Data API usando un viewToken de un solo uso.
3. El Backend Card Data API valida sesión, MFA, autorización, titularidad y vigencia del viewToken.
4. El backend descifra el PAN desde HSM y consulta el CVV2 en Pomelo.
5. El iframe renderiza el PAN enmascarado por defecto y permite revelación temporal mediante acción explícita del tarjetahabiente.
6. Después de 30 segundos, los datos se auto-ocultan, se eliminan del DOM y se limpian de memoria.

El diseño diferencia los componentes dentro del CDE de aquellos propuestos fuera del CDE.

Componentes dentro del CDE propuesto:

- Iframe Card Data alojado en secure-data.credibanco.com o dominio definido.
- Backend Card Data API.
- HSM Thales payShield.
- Canal seguro iframe ↔ backend.
- Canal seguro backend ↔ HSM/Vault.
- Integración segura backend ↔ Pomelo para CVV2 dinámico.

Componente propuesto fuera del CDE:

- Portal Tarjetahabiente de la entidad emisora, siempre que no procese, transmita, almacene ni renderice PAN/CVV2. Esta clasificación queda sujeta a validación formal por Seguridad de la Información y el asesor/auditor PCI.

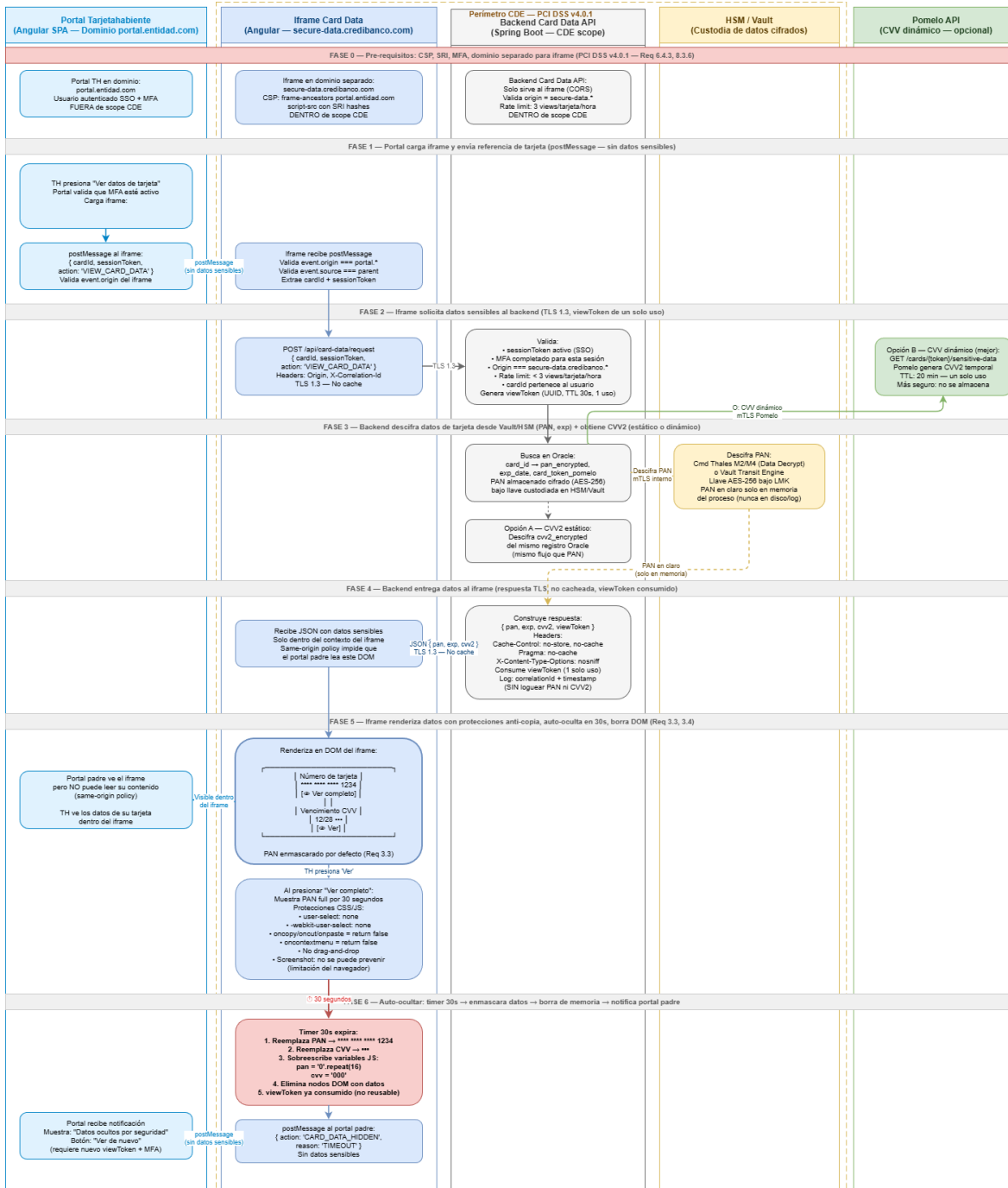


Diagrama 1. – Diagrama de Arquitectura

Descripción de componentes

Identificador	Componente	Descripción
CSA-001	Portal Tarjetahabiente	Portal autenticado desde el cual el tarjetahabiente solicita visualizar los datos de su tarjeta. No procesa, transmite, almacena ni renderiza PAN/CVV2. Su función es cargar el iframe seguro y enviar referencias no sensibles mediante postMessage.
CSA-002	Iframe Card Data	Componente frontend seguro alojado en dominio controlado por Credibanco, por ejemplo secure-data.credibanco.com. Es el único componente frontend autorizado para renderizar PAN completo, fecha de vencimiento y CVV2.
CSA-003	Backend Card Data API	Servicio backend responsable de validar sesión, MFA, autorización, titularidad de la tarjeta, vigencia del viewToken, límites de uso y obtención de datos sensibles. Se considera dentro del CDE propuesto.
CSA-004	HSM Thales payShield / Vault	Componente de custodia criptográfica responsable de proteger llaves y permitir el descifrado controlado del PAN. El PAN permanece cifrado en almacenamiento y solo se descifra durante el flujo autorizado de visualización.
CSA-005	Pomelo API	Proveedor externo encargado de generar o entregar el CVV2 dinámico con TTL limitado. El CVV2 no se almacena en sistemas de Credibanco.
CSA-006	MFA Provider	Servicio encargado de validar el segundo factor o autenticación reforzada antes de permitir la visualización de datos sensibles.
CSA-007	Servicio de auditoría / SIEM	Plataforma responsable de recibir eventos de visualización, intentos, rechazos, errores y consumo de tokens, sin registrar PAN, CVV2 ni payloads sensibles.
CSA-008	WAF / Seguridad perimetral	Capa de protección para mitigar ataques web, automatización, abuso de endpoints y patrones anómalos de consumo.
CSA-009	Servicio de rate limiting	Componente lógico o técnico encargado de limitar visualizaciones por usuario, tarjeta, IP y ventana de tiempo.
CSA-010	Repositorio operacional de tarjetas	Fuente de datos para validar titularidad, estado de la tarjeta, relación usuario-tarjeta e identificadores internos. No debe exponer PAN en claro al Portal Tarjetahabiente.

CSA-011	Módulo de configuración de dominios autorizados	Administra la lista de portales autorizados para embeber el iframe y consumir el flujo de visualización.
CSA-012	Motor de security headers / CSP	Configuración responsable de aplicar frame-ancestors, script-src, SRI, CORS restringido y headers de no almacenamiento.

Tabla 1. – Listado Responsabilidades de Componentes

Descripción del proceso

Fase 1. Solicitud de visualización desde el Portal Tarjetahabiente

El tarjetahabiente ingresa al Portal Tarjetahabiente mediante su sesión autenticada y selecciona la opción para visualizar los datos de su tarjeta prepago.

Antes de iniciar el flujo, el portal debe garantizar que el usuario tenga una sesión activa y que la tarjeta seleccionada pertenezca al usuario autenticado. El portal no solicita ni recibe PAN completo, CVV2 ni datos sensibles de tarjeta.

El Portal Tarjetahabiente carga el iframe seguro alojado en el dominio controlado por Credibanco y le envía una referencia no sensible mediante postMessage.

La información enviada al iframe se limita a:

- cardId opaco.
- Identificador de sesión o referencia no sensible.
- Acción solicitada.
- correlationId.

No se envían mediante postMessage:

- PAN completo.
- CVV2.
- Datos equivalentes de tarjeta.
- Credenciales del usuario.
- Tokens reutilizables de autenticación.
- Información que permita reconstruir el PAN.

Fase 2. Validación del origen y solicitud de viewToken

El iframe recibe el mensaje del Portal Tarjetahabiente y valida estrictamente el origen de la comunicación.

El iframe deberá validar como mínimo:

- event.origin.
- event.source.
- Dominio autorizado del portal.
- Estructura del mensaje.
- Acción solicitada.
- Formato del cardId.
- correlationId.

Si el origen no se encuentra autorizado o el mensaje no cumple la estructura esperada, el iframe rechaza la solicitud y genera un evento de auditoría.

Si la validación es exitosa, el iframe solicita al Backend Card Data API un viewToken de un solo uso para iniciar la operación de visualización.

El viewToken deberá cumplir las siguientes condiciones:

- TTL máximo de 30 segundos.
- Uso único.
- Asociación a usuario.
- Asociación a tarjeta.
- Asociación a sesión.
- Asociación a MFA vigente.
- Asociación a origen autorizado.
- Asociación a operación y correlationId.

Fase 3. Validación de seguridad en Backend Card Data API

El Backend Card Data API recibe la solicitud del iframe y ejecuta las validaciones de seguridad antes de obtener o entregar cualquier dato sensible.

El backend valida:

- Sesión activa del tarjetahabiente.
- MFA vigente.
- Titularidad de la tarjeta.

- Estado de la tarjeta.
- Autorización del usuario para visualizar datos.
- Vigencia del viewToken.
- No reutilización del viewToken.
- Origen autorizado del iframe.
- Límites de visualización por tarjeta, usuario, IP y ventana de tiempo.
- Riesgo de la solicitud.
- Trazabilidad mediante correlationId.

Si alguna validación falla, el backend rechaza la solicitud, no entrega datos sensibles y registra el evento de auditoría correspondiente.

Fase 4. Obtención controlada de PAN y CVV2

Una vez superadas las validaciones, el Backend Card Data API obtiene los datos sensibles requeridos para la visualización.

Para el PAN completo, el backend invoca el HSM definido para realizar el descifrado controlado del dato. El PAN permanece cifrado en almacenamiento y solo se descifra durante el tiempo estrictamente necesario para construir la respuesta autorizada al iframe.

Para el CVV2, se adopta el enfoque de CVV2 por Pomelo. El Backend Card Data API consulta a Pomelo en tiempo real para obtener un CVV2 temporal con TTL limitado.

El CVV2 no se almacena en sistemas de Credibanco, no se registra en logs, no se persiste en bases de datos, no se envía al Portal Tarjetahabiente y no queda disponible fuera del flujo de visualización autorizado.

Si Pomelo no se encuentra disponible, el sistema indicara que no está disponible la operación. En ese escenario, el iframe deberá informar al tarjetahabiente que la visualización no se encuentra disponible temporalmente.

Fase 5. Entrega segura de datos al iframe

El Backend Card Data API entrega los datos sensibles exclusivamente al iframe seguro, usando canal cifrado mediante TLS 1.3 o el estándar corporativo vigente aprobado por Seguridad de la Información.

La respuesta deberá incluir headers de no almacenamiento, tales como:

- Cache-Control: no-store.
- Pragma: no-cache.
- X-Content-Type-Options: nosniff.

La respuesta no deberá ser almacenada en caché por el navegador, proxies, balanceadores, componentes intermedios o herramientas de observabilidad.

El backend deberá evitar registrar en logs:

- PAN completo.
- CVV2.
- Payloads completos.
- Respuestas completas.
- Datos sensibles equivalentes.

Después de entregar la respuesta, el viewToken deberá quedar consumido e invalidado.

Fase 6. Renderización controlada en el iframe

El iframe renderiza la información de la tarjeta bajo un modelo de exposición controlada.

Por defecto, el iframe debe mostrar el PAN enmascarado, visualizando únicamente los últimos cuatro dígitos. El PAN completo y el CVV2 solo podrán revelarse mediante una acción explícita del tarjetahabiente.

La visualización temporal deberá cumplir:

- PAN enmascarado por defecto.
- Acción explícita para revelar PAN completo y CVV2.
- Temporizador máximo de 30 segundos.
- Auto-ocultamiento al finalizar el tiempo.
- Eliminación de datos sensibles del DOM.
- Limpieza de referencias en memoria del componente.

- No almacenamiento en localStorage, sessionStorage, cookies, IndexedDB ni caché.
- Notificación al portal padre únicamente con estado de la operación, sin datos sensibles.

Las protecciones anti-copia, tales como bloqueo de selección de texto, eventos de copiar/cortar/pegar y menú contextual, se implementan como controles de reducción de exposición. No se consideran controles absolutos, ya que no impiden capturas de pantalla, fotografías externas, malware en el endpoint o inspección avanzada del navegador.

Fase 7. Auditoría y cierre de la operación

Cada evento del flujo debe generar auditoría técnica y de seguridad.

La auditoría deberá registrar como mínimo:

- Identificador interno de tarjeta.
- Usuario.
- Entidad emisora, si aplica.
- Timestamp.
- Dirección IP.
- User-agent.
- Origen autorizado.
- Resultado de la operación.
- Motivo de rechazo, si aplica.
- Consumo o expiración del viewToken.
- correlationId.

La auditoría no deberá registrar PAN, CVV2, payloads sensibles ni respuestas completas.

Una vez finalizada la visualización, el iframe notifica al Portal Tarjetahabiente únicamente el estado de la operación. El portal no recibe datos sensibles en ningún momento del flujo.

Controles de seguridad propuestos

Control	Descripción
Separación de dominios	El Portal Tarjetahabiente y el iframe operan en dominios diferentes.
Iframe controlado por Credibanco	Los datos sensibles se renderizan únicamente en secure-data.credibanco.com o dominio equivalente aprobado.
Same-origin policy	El portal padre no puede leer el DOM interno del iframe.
postMessage restringido	Solo se aceptan mensajes desde dominios autorizados y sin datos sensibles.
cardId opaco	Identificador no derivado del PAN, no reversible y no enumerable.
MFA previo	Se requiere autenticación reforzada antes de cada visualización.
viewToken de un solo uso	Token efímero con TTL de 30 segundos, asociado a usuario, tarjeta, sesión y operación.
PAN cifrado en reposo	El PAN permanece cifrado y solo se descifra bajo flujo autorizado.
HSM/Vault	Custodia y operación criptográfica controlada dentro del CDE.
CVV2 dinámico	CVV2 generado por Pomelo en tiempo real, sin almacenamiento en Credibanco.
TLS 1.3	Protección de canal entre iframe y backend.
mTLS	Protección de canal entre backend y HSM/Vault o integraciones críticas.
No caché	Headers para impedir almacenamiento de respuestas sensibles.
No almacenamiento local	Prohibido almacenar datos sensibles en mecanismos del navegador.
Auto-ocultamiento	PAN/CVV2 visibles máximo por 30 segundos.
Limpieza de DOM y memoria	Eliminación de datos sensibles después de la visualización.
Rate limiting	Control de visualizaciones por tarjeta, usuario, IP y ventana de tiempo.
Auditoría segura	Registro de eventos sin PAN, CVV2 ni payloads sensibles.
CSP y CORS restringidos	Limitación de orígenes, scripts y portales autorizados.

Riesgos identificados

Riesgo	Descripción	Mitigación propuesta
Inclusión no deseada del Portal TH en el alcance CDE	Aunque el Portal TH no procesa ni renderiza PAN/CVV2, una mala implementación de postMessage, integración directa o exposición indirecta podría llevar a que sea considerado dentro del CDE.	Mantener el Portal TH limitado a cargar el iframe y enviar únicamente identificadores opacos. Validar formalmente el alcance con Seguridad de la Información y el asesor/auditor PCI.
Acceso no autorizado a PAN/CVV2	Un usuario podría intentar visualizar datos de una tarjeta que no le pertenece o para la cual no tiene permisos.	Validar sesión, MFA, titularidad, autorización, estado de tarjeta, viewToken, origen y rate limiting en el Backend Card Data API antes de entregar datos sensibles.
Manipulación del cardId	El cardId podría ser alterado para intentar consultar datos de otra tarjeta.	Usar identificadores opacos, no reversibles, no enumerables y no derivados del PAN. El backend no debe confiar solo en el cardId; debe validar titularidad y autorización.

Reutilización del viewToken	Un atacante podría intentar reutilizar un viewToken previamente emitido para obtener nuevamente datos sensibles.	viewToken de un solo uso, TTL máximo de 30 segundos, invalidación inmediata después del consumo, expiración o error de validación.
Robo o exposición del viewToken	Un token interceptado o expuesto podría ser utilizado dentro de la ventana de vigencia.	TTL corto, uso único, asociación a usuario, sesión, tarjeta, origen, MFA y correlationId. Comunicación cifrada mediante TLS 1.3.
Origen no autorizado usando el iframe	Un portal no autorizado podría intentar embeber el iframe para invocar el flujo de visualización.	Configurar CSP con frame-ancestors restringido a dominios autorizados. Validar event.origin y lista blanca de portales permitidos.
Abuso de postMessage	Mensajes malformados o enviados desde orígenes no autorizados podrían intentar activar funcionalidades del iframe.	Validar event.origin, event.source, estructura del mensaje, acción permitida, formato del cardId y correlationId. Rechazar cualquier mensaje no autorizado.
Exposición de PAN/CCV2 por caché	El navegador, proxies, balanceadores o componentes intermedios podrían almacenar respuestas con datos sensibles.	Usar headers Cache-Control: no-store, Pragma: no-cache, X-Content-Type-Options: nosniff y validar que no exista caché en capas intermedias.
Registro accidental de PAN/CCV2 en logs	Los datos sensibles podrían quedar registrados en logs técnicos, trazas, herramientas APM o SIEM.	Sanitización de logs, exclusión de payloads sensibles, enmascaramiento, pruebas negativas y lineamientos de no logging en frontend, backend y observabilidad.
Exposición de datos en el navegador del usuario	Aunque el iframe esté protegido, el navegador y dispositivo del tarjetahabiente no son entornos controlados por Credibanco.	Limitar la visualización a 30 segundos, auto-ocultar datos, limpiar DOM y memoria, requerir MFA y registrar auditoría. Documentar este punto como riesgo residual.
Captura de pantalla o fotografía externa	El usuario o un tercero podría tomar una captura o fotografía durante la visualización.	Controles de reducción de exposición, timer de 30 segundos, auto-ocultamiento, advertencias al usuario y auditoría. Este riesgo no puede eliminarse completamente desde la arquitectura web.
Malware o keylogger en el endpoint del usuario	Un equipo comprometido podría capturar lo que se visualiza en pantalla.	Riesgo residual del endpoint del usuario. Mitigación parcial mediante exposición temporal, MFA, reducción de frecuencia de visualización y monitoreo de patrones anómalos.
Inspección avanzada mediante herramientas del navegador	Un usuario avanzado podría intentar inspeccionar DOM, memoria o respuestas de red en su navegador.	Auto-ocultamiento, no almacenamiento local, headers no-cache, minimización del tiempo de exposición y no entrega de datos al portal padre. Las protecciones anti-copia se documentan como disuasivas.

Exceso de visualizaciones por usuario o tarjeta	Un usuario o atacante podría intentar visualizar reiteradamente los datos sensibles.	Rate limiting por usuario, tarjeta, IP y ventana de tiempo. Como referencia inicial, máximo 3 visualizaciones por tarjeta por hora, sujeto a validación de Seguridad.
Falla en MFA o ausencia de step-up	Si no se exige MFA antes de visualizar datos, aumentaría el riesgo de exposición ante cuentas comprometidas.	MFA obligatorio antes de cada visualización. Si MFA no está disponible o no es exitoso, no se permite la visualización.
Indisponibilidad del MFA Provider	La visualización podría quedar bloqueada si el proveedor MFA no está disponible.	Definir manejo de indisponibilidad seguro: no permitir visualización sin MFA y mostrar mensaje controlado al usuario. Registrar evento operativo y de seguridad.
Indisponibilidad de Pomelo para CVV2	Si Pomelo no responde, no se podría obtener CVV2.	No usar fallback con CVV2 estático almacenado. Informar indisponibilidad temporal al usuario, activar circuit breaker, monitoreo y auditoría.
Almacenamiento indebido de CVV2 estático	Guardar CVV2 estático, incluso cifrado, incrementaría el riesgo y la carga de cumplimiento PCI.	Descartar almacenamiento de CVV2 estático en Credibanco.
Exposición del PAN durante descifrado	El PAN debe descifrarse para visualizarse, generando una ventana de exposición controlada.	Descifrado únicamente bajo flujo autorizado, dentro del perímetro CDE, usando HSM/Vault, sin persistencia, sin logs y con eliminación posterior de referencias.
Mala configuración de CORS	Una configuración permisiva podría permitir que otros orígenes consuman el Backend Card Data API.	Restringir CORS exclusivamente al dominio autorizado del iframe. Validar configuración mediante pruebas de seguridad.
Mala configuración de CSP	Una política CSP débil podría permitir carga de scripts no autorizados o embedding desde dominios no aprobados.	Configurar frame-ancestors, script-src restringido, SRI cuando aplique y revisión periódica de configuración.
Inyección o manipulación de scripts en el iframe	Un script comprometido podría acceder a datos sensibles renderizados.	CSP estricta, SRI, control de dependencias, revisión AppSec, hardening del pipeline y análisis de seguridad antes de producción.
Fallas en limpieza de DOM o memoria	Los datos sensibles podrían permanecer accesibles más allá del tiempo autorizado.	Implementar auto-ocultamiento, limpieza del DOM, limpieza de variables, pruebas automatizadas y revisión de código frontend.
Visualización de datos de tarjeta en estado no permitido	Se podrían mostrar datos de tarjetas bloqueadas, canceladas, vencidas o no habilitadas para visualización.	Validar estado de la tarjeta en Backend Card Data API antes de entregar PAN/CVV2.
Falta de trazabilidad para investigación	Si la auditoría es insuficiente, no se podrían investigar accesos indebidos o eventos anómalos.	Registrar usuario, cardId interno, IP, user-agent, timestamp, origen, resultado, motivo de rechazo y correlationId, sin datos sensibles.
Dependencia de controles disuasivos como si fueran absolutos	Bloqueo de copiar/pegar o selección de texto podría ser interpretado erróneamente como protección fuerte.	Documentar estos controles como reducción de exposición. La mitigación principal es MFA, token de

		un solo uso, TTL corto, auto-ocultamiento y auditoría.
Acceso administrativo indebido a componentes CDE	Personal no autorizado podría acceder a componentes que procesan datos sensibles.	Mínimo privilegio, segregación de funciones, MFA administrativo, trazabilidad, revisión periódica de accesos y controles de operación sobre CDE, inaccesible o cifrada para protección .
Falta de evidencia para auditoría PCI	Aunque el diseño sea adecuado, la ausencia de evidencias técnicas podría impedir soportar el cumplimiento.	Generar evidencias de CSP, CORS, headers no-cache, logs sanitizados, MFA, tokens de un solo uso, rate limiting, pruebas AppSec y pentesting.

Aplicaciones y/o soluciones afectadas

Aplicación / solución	Impacto
Portal Tarjetahabiente	Deberá cargar el iframe seguro y enviar únicamente referencias no sensibles. No deberá recibir ni renderizar PAN/CVV2.
Iframe Card Data	Nuevo componente o ajuste de componente existente para renderización segura de datos sensibles.
Backend Card Data API	Servicio responsable de validaciones, autorización, obtención de PAN/CVV2 y entrega controlada al iframe.
HSM Thales payShield / Vault	Componente requerido para custodia criptográfica y descifrado controlado del PAN.
Pomelo API	Integración requerida para generación o consulta de CVV2 dinámico.
MFA Provider	Servicio requerido para autenticación reforzada antes de cada visualización.
Plataforma de auditoría / SIEM	Debe recibir eventos del flujo sin incluir datos sensibles.
WAF / Seguridad perimetral	Debe proteger endpoints asociados al iframe y Backend Card Data API.
Repositorio operacional de tarjetas	Debe permitir validación de titularidad, estado de tarjeta y relación usuario-tarjeta.
Configuración CSP/CORS	Debe mantener dominios autorizados, restricciones de frame y políticas de seguridad.

ANEXOS

<Se incluye documentos de referencia que hacen parte del diseño de Arquitectura >

<Autores: Arquitecto>

NOMBRE	OBSERVACIONES
	<Link de referencia del anexo>

Tabla 2.